

RaceDay - API Endpoint Plan

This plan lists every endpoint the RaceDay REST API will expose in Part 2. It covers Authentication, User Profile, Events, Categories, Event Enrolments, and Results. The endpoints, routes, and roles below are designed to match the RaceDay ERD ([ERD_UML.png](#)) and [database_schema.sql](#) exactly, so that Part 2's implementation can be built directly against this plan without unexplained deviation.

Role key: **None** = public, no login required. **Any** = any logged-in user (Organiser or Participant). **Organiser** = logged-in Organiser only. **Participant** = logged-in Participant only. Where a route says "(owner)", the API must also check that the logged-in Organiser owns the specific Event/Category being modified, not just that they hold the Organiser role.

1. Authentication

HTTP Method	Route	Description	Role Required	Request Body	Expected Response
POST	/api/auth/register	Creates a new account as either an Organiser or a Participant.	None (public)	{ "role": "Organiser" "Participant", "fullName": string, "email": string, "password": string, "dateOfBirth"?: "YYYY-MM-DD" } (dateOfBirth required for a Participant, ignored for an Organiser)	201 Created - returns the new user's id, role, and email. 400 Bad Request - missing/invalid fields (e.g. dateOfBirth missing for a Participant). 409 Conflict - email already registered.
POST	/api/auth/login	Authenticates a user and issues a JWT access token.	None (public)	{ "email": string, "password": string }	200 OK - returns JWT token, role, and expiry. 401 Unauthorized - invalid email or password.

2. User Profile

HTTP Method	Route	Description	Role Required	Request Body	Expected Response
GET	/api/users/me	Returns the profile of the currently logged-in user (Organiser or Participant).	Any (logged in)	None	200 OK - returns profile fields appropriate to the user's role. 401 Unauthorized - missing/invalid token.
PUT	/api/users/me	Updates the profile of the currently logged-in user.	Any (logged in)	{ "fullName"?: string, "dateOfBirth"?: "YYYY-MM-DD" } (Participant only for dateOfBirth)	200 OK - returns updated profile. 400 Bad Request - invalid field values. 401 Unauthorized - missing/invalid token.

3. Events

HTTP Method	Route	Description	Role Required	Request Body	Expected Response
GET	/api/events	Lists all upcoming events, optionally filtered by date range or location via query string.	None (public)	None	200 OK - returns array of events.
GET	/api/events/{id}	Returns full details for a single event, including its categories.	None (public)	None	200 OK - returns event with nested categories. 404 Not Found - event does not exist.
POST	/api/events	Creates a new event owned by the logged-in Organiser.	Organiser	{ "eventName": string, "description"?: string, "eventDate": "YYYY-MM-DD", "location": string, "distance": number, "eventType": string }	201 Created - returns the new event. 400 Bad Request - validation failure. 401 Unauthorized.
PUT	/api/events/{id}	Updates an event's details.	Organiser (owner)	{ "eventName"?: string, "description"?: string, "eventDate"?: "YYYY-MM-DD", "location"?: string, "distance"?: number, "eventType"?: string }	200 OK - returns updated event. 403 Forbidden - not the owning organiser. 404 Not Found.
DELETE	/api/events/{id}	Deletes an event and its categories.	Organiser (owner)	None	204 No Content. 403 Forbidden - not the owning organiser. 404 Not Found.

4. Categories

HTTP Method	Route	Description	Role Required	Request Body	Expected Response
GET	/api/events/{eventId}/categories	Lists all categories offered for a specific event.	None (public)	None	200 OK - returns array of categories. 404 Not Found - event does not exist.
POST	/api/events/{eventId}/categories	Adds a new category (e.g. Half Marathon, 10km Fun Run) to an event.	Organiser (owner)	{ "categoryName": string }	201 Created - returns the new category. 400 Bad Request. 403 Forbidden. 404 Not Found - event does not exist.
PUT	/api/categories/{id}	Updates a category's details.	Organiser (owner)	{ "categoryName"?: string }	200 OK - returns updated category. 403 Forbidden. 404 Not Found.
DELETE	/api/categories/{id}	Deletes a category.	Organiser (owner)	None	204 No Content. 403 Forbidden. 404 Not Found. 409 Conflict - category already has enrolments.

5. Event Enrolments

HTTP Method	Route	Description	Role Required	Request Body	Expected Response
POST	/api/categories/{categoryId}/enrolments	Enters the logged-in Participant into a category for an event. The API resolves and stores the category's parent EventID on the enrolment automatically - the caller only supplies the category.	Participant	{ } (no body required - participant is taken from the auth token)	201 Created - returns the new enrolment (including its eventId). 404 Not Found - category does not exist. 409 Conflict - already enrolled in this category.
GET	/api/enrolments/me	Lists all of the logged-in Participant's own enrolments, past and upcoming.	Participant	None	200 OK - returns array of the participant's enrolments.
GET	/api/events/{eventId}/enrolments	Lists every enrolment across all categories for an event (used by the Organiser to see who has entered).	Organiser (owner)	None	200 OK - returns array of enrolments with participant and category details. 403 Forbidden . 404 Not Found .
DELETE	/api/enrolments/{id}	Withdraws the logged-in Participant from an event they enrolled in.	Participant (owner)	None	204 No Content . 403 Forbidden - not the owning participant. 404 Not Found .

6. Results

HTTP Method	Route	Description	Role Required	Request Body	Expected Response
POST	/api/enrolments/{enrolmentId}/results	Captures a participant's result for an enrolment they completed.	Organiser	{ "finishTime": "HH:MM:SS", "position"? : number }	201 Created - returns the new result. 403 Forbidden - not an organiser of that event. 404 Not Found - enrolment does not exist. 409 Conflict - a result already exists for this enrolment (use PUT instead).
PUT	/api/results/{id}	Corrects/updates a previously captured result.	Organiser	{ "finishTime"? : "HH:MM:SS", "position"? : number }	200 OK - returns updated result. 403 Forbidden . 404 Not Found .
GET	/api/results/me	Returns the logged-in Participant's personal result history across all events.	Participant	None	200 OK - returns array of the participant's results.
GET	/api/events/{eventId}/results	Returns the full results/leaderboard for an event, grouped by category.	None (public)	None	200 OK - returns array of results with participant name, category, finish time, and position. 404 Not Found - event does not exist.

Notes

- Additional endpoints beyond the six required functional areas: none were needed - the areas above (Auth, Profile, Events, Categories, Enrolments, Results) fully cover the functional requirements for RaceDay.
- Ownership checks (e.g. "Organiser (owner)") are enforced at the API level in Part 2 by comparing the **OrganiserID** on the JWT token against the **OrganiserID** stored on the Event (or the **EventID** on the parent Event of a Category/Enrolment).
- **Results** no longer records who captured a result (no **recordedByOrganiserId**) - only the finish time and position are stored, per the reviewed ERD. Ownership for POST/PUT on a result is still checked, via the enrolment's category's event, not via a stored recorder field.
- All routes are prefixed **/api/** and use plural nouns for collections, consistent with the example format provided in the assignment brief.